

# Go-Live Checklist

M-Pesa STK Push on n8n

# Go-Live Checklist : M-Pesa STK Push on n8n

---

Print this. Tick every box before switching `MPESA_ENV` from `sandbox` to `production` .



## Safaricom / Daraja

---

- ☐ Production app created & approved in Daraja portal
- ☐ Business shortcode allocated (PayBill or BuyGoods Till)
- ☐ Production Consumer Key received
- ☐ Production Consumer Secret received
- ☐ Production Passkey received (different from sandbox!)
- ☐ Callback URL registered & approved with Safaricom
- ☐ If required: callback server IP whitelisted with Safaricom
- ☐ Go-Live letter / email on file



## Infrastructure

---

- ☐ VPS running Ubuntu 22.04+ with 2 GB RAM minimum
- ☐ Domain pointing to VPS (A record)
- ☐ HTTPS cert valid (Let's Encrypt auto-renew tested)
- ☐ NTP enabled ( `timedatectl` shows "synchronized: yes")
- ☐ Timezone set to `Africa/Nairobi`
- ☐ Firewall: only 22, 80, 443 open
- ☐ fail2ban installed



## Secrets

---

- ☐ `.env` file permissions `600` , owned by root
- ☐ `N8N_ENCRYPTION_KEY` is a fresh random 32-char string (not the default)
- ☐ `N8N_BASIC_AUTH_PASSWORD` is strong & unique
- ☐ Postgres password rotated from default
- ☐ All sandbox credentials removed from `.env`
- ☐ Secrets backed up in a password manager (1Password, Bitwarden)

## Pre-flight tests (on production creds, small amount)

---

- ☐ OAuth token retrieved successfully
- ☐ STK push triggers prompt on your real phone
- ☐ You complete payment with PIN → callback arrives
- ☐ Row in `mpesa_transactions` has `status = success` and `mpesa_receipt_number`
- ☐ Reconciliation workflow runs on schedule
- ☐ A deliberately cancelled transaction gets marked `cancelled` within 7 min

## Monitoring & alerting

---

- ☐ n8n execution error notifications configured (email/Slack)
- ☐ Postgres backup job scheduled daily
- ☐ Backup restore tested at least once
- ☐ Uptime monitor on the callback URL (UptimeRobot / BetterStack)
- ☐ Alert on >5 failed transactions in 10 minutes

## Operational

---

- ☐ On-call rotation defined
- ☐ Runbook for "callbacks not arriving" documented
- ☐ Customer support can look up a transaction by phone / receipt number
- ☐ Daily reconciliation report emailed to finance

## Compliance

---

- ☐ Privacy policy updated to mention M-Pesa data handling
- ☐ Transaction logs retention policy defined (recommended: 7 years for ODPC)
- ☐ Customer phone numbers encrypted at rest (optional but recommended)
- ☐ Data Protection Act (Kenya) registration if processing > 10k records

## Launch day

---

- ☐ Deploy `MPESA_ENV=production` config
- ☐ Verify webhook URL responds `200 OK` from external curl
- ☐ Process one real transaction end-to-end
- ☐ Announce to team

- ☐ Monitor executions dashboard for first 2 hours

**Signed off by:** \_\_\_\_\_ **Date:** \_\_\_\_\_